

Securing Shared University Lab Computers Against Credential Theft, Browser Data Leakage, and Keyloggers

TL;DR

- The single most effective defense is a layered baseline: **standard (non-admin) user accounts + reboot-to-restore (Deep Freeze or Unified Write Filter) + enforced browser lockdown (disable Chrome/Edge sync and the built-in password manager) + USB execute-blocking**. The 2025 BeyondTrust Microsoft Vulnerabilities Report (12th edition) states that removing local admin rights and enforcing least privilege can remediate or mitigate up to 75% of Microsoft critical vulnerabilities, and reboot-to-restore wipes any keylogger or harvested data on restart.
- **No browser privacy feature protects a machine that is already compromised:** incognito/private mode does NOT stop an installed keylogger or malicious extension; unprivileged Python/C++ keyloggers run fine from the Startup folder without admin rights; and Windows Smart App Control/Defender does NOT reliably catch novel unsigned homemade keyloggers. Execution *prevention* matters more than detection.
- This is a **gendered safety issue, not just an IT issue**: in Bangladesh, Police Cyber Support for Women logged 60,808 complaints from women by September 2024 (18% account hacking, 17% blackmail), and shared-device privacy failures map directly onto image-based abuse. A body of South Asia/Bangladesh academic research — including SOUPS 2018 work co-authored by Nova Ahmed of North South University — ties shared-device security gaps to disproportionate harm to women.

Key Findings

Academic research grounding

- **Shared/household device sharing** is well documented in HCI security literature. The foundational study is Matthews, Liao, Turner, Berkovich, Reeder & Consolvo, "'She'll Just Grab Any Device That's Closer': A Study of Everyday Device & Account Sharing in Households," CHI 2016 (pp. 5921–5932). It establishes that the industry's assumption of devices/accounts as personal is false and that sharing is the norm.
- **Bangladesh-specific, peer-reviewed work exists and is directly citable:** Ahmed, Haque, Haider, Chen & Dell, "'Everyone Has Some Personal Stuff': Designing to Support Digital Privacy with Shared Mobile Phone Use in Bangladesh," CHI 2019 (DOI 10.1145/3290605.3300410); and the earlier Ahmed, Haque, Chen & Dell, "Digital Privacy Challenges with Shared Mobile Phone Use in Bangladesh," PACM HCI / CSCW 2017 (Vol. 1, Article 17, DOI 10.1145/3134652).
- **Gendered harm in South Asia:** Sambasivan, Checkley, Batool, Ahmed, Nemer, Gaytán-Lugo, Matthews, Consolvo & Churchill, "'Privacy is not for me, it's for those rich women':

Performative Privacy Practices on Mobile Phones by Women in South Asia," Fourteenth Symposium on Usable Privacy and Security (SOUPS 2018), USENIX, Baltimore, Aug 12-14 2018, pp. 127-142, ISBN 978-1-939133-10-6 (IAPP SOUPS Privacy Award). **Co-authored by Nova Ahmed of North South University**, based on 199 women (India 103, Pakistan 52, Bangladesh 44). Verbatim key finding: *"An overarching theme in our results is that participants had to cope with an expectation that they allow their phones and accounts to be frequently monitored by a variety of social relations."* The paper documents coercive monitoring — e.g., in Bangladesh, husbands working abroad installed tracking/spyware tools on their wives' phones — and women's dependence on male relatives who create and log into their accounts for them. (usenix)

- **Keylogger detection/prevention** is a mature research area. Representative peer-reviewed sources: "Keylogger Detection and Prevention," Journal of Physics: Conference Series Vol. 2007, Art. 012005 (IOP, 2021); foundational work on unprivileged user-space keylogger detection (Ortolani et al.); and recent ML-based detection surveys (XGBoost/LightGBM/CatBoost website-keylogger frameworks and dendritic-cell/ensemble approaches, 2024-2025). The consistent finding: signature-based antivirus reliably catches *known* keyloggers but fails on *unknown/custom* ones. (IOPscience)

Real institutional lab-lockdown practice

- **Reboot-to-restore is the dominant control.** Faronics Deep Freeze is licensed campus-wide at institutions such as the University of Alabama and is used at the University of Nevada, Reno — which, per Faronics, previously "spent countless hours daily cleaning and updating 250 workstations to remove unapproved software and private student information left on shared computers." On reboot, all changes — including any installed malware or harvested credential files — are discarded. (University of Alabama)
- **Microsoft's native equivalent is Unified Write Filter (UWF)**, available in Windows 10/11 Enterprise, Education, and IoT Enterprise editions (**not** Pro — confirmed in Microsoft Q&A community reports). It redirects all disk writes to a RAM/disk overlay cleared on reboot; Microsoft Learn explicitly markets it for "thin clients and workspaces that have frequent guests, like school, library or hotel computers." Managed via (uwfmgr.exe) (or CSP/WMI/PowerShell). Windows also offers Shared PC Mode ("Set up a shared or guest PC") for automatic account cleanup and guest profiles.
- **Browser lockdown via managed policy** is standard. For Google Workspace for Education, admins disable Chrome sync at **Admin console → Apps → Google Workspace → Google Chrome Sync → Edit Service → OFF for everyone** (or per organizational unit via Override). On managed/enrolled browsers, the (SyncDisabled=1), (BrowserSignin=2), and (RestrictSigninToPattern) policies enforce this; the org should also "Block multiple sign-in access" and restrict sign-in to the school domain pattern (per Google's Chrome Enterprise/Education Help and the Linewize school-policy guide). Google's own guidance: to fully turn off sync, "turn off the service in the Google Admin console."

- **USB control:** real institutions use Group Policy "Removable Storage Access" deny rules. The most defensible posture is a **default-deny with hardware-ID allowlisting** — enable Device Installation Restrictions ("Prevent installation of removable devices" + "Prevent installation of devices not described by other policy settings," then allow specific approved device IDs). For credential/keylogger threats specifically, "**Removable Disks: Deny execute access**" is the highest-value single setting because it blocks running executables/payloads off USB while still permitting data use. Microsoft Defender for Endpoint Device Control and Intune offer more manageable, auditable enforcement than raw GPO (and best practice is to run device control in **audit mode for ~30 days first** to inventory legitimate devices).
- **Application control:** AppLocker and Windows Defender Application Control (WDAC) restrict which executables non-admins can run. Microsoft now recommends **WDAC over AppLocker** ("Microsoft is no longer investing in AppLocker. AppLocker will only receive security fixes"). Microsoft's own open-source **AaronLocker** project automates robust allowlisting that "restrict[s] program and script execution by non-administrative users." Note the documented limitation: path-only rules are bypassable by renaming/copying `powershell.exe`, so hash- or publisher/certificate-based rules are required.
- **Endpoint monitoring:** Sysmon (Sysinternals) forwarded into **Wazuh** (open-source SIEM) is a common, low-cost university/SOC-lab pattern for detecting process creation, persistence (Run keys, Startup folder, scheduled tasks), and suspicious behavior — appropriate for a resource-constrained university. There is even peer-reviewed pedagogy on it: "Teaching Endpoint Protection through Wazuh," Journal of the Colloquium for Information Systems Security Education (CISSE).

Specific technical questions answered

1. **Does incognito/private browsing protect against an already-installed keylogger or extension? NO.** Incognito only prevents the *browser* from saving local history/cookies/form data after the session; it does not hide anything from the OS or other running software. A keylogger captures keystrokes (including typed URLs, usernames, passwords), and many also capture clipboard contents, window titles, and screenshots — fully reconstructing an incognito session. (Confirmed across Protectstar, BGR, and forensic write-ups.) [Quora](#)
2. **Can browser extensions act as keyloggers, and do malicious ones exist in the stores? YES.** Extensions granted "read and change data on all websites" can log form inputs and harvest session tokens *after* MFA. Real, documented campaigns:
 - **Cyberhaven supply-chain compromise (Dec 2024):** a phishing attack on a developer's Chrome Web Store access pushed a malicious update; per BleepingComputer/ExtensionTotal, the same injected code reached at least 35 extensions collectively used by roughly 2,600,000 people (Cyberhaven's own extension, v24.10.4, had ~400,000 users and was malicious Dec 25–26, 2024).
 - **Enterprise-impersonation cluster (Jan 2026):** Socket's Threat Research Team disclosed five coordinated Chrome extensions (2,300+ combined installs) posing as

Workday/SAP SuccessFactors/NetSuite tools; auth cookies "were exfiltrated every 60 seconds to remote command-and-control servers," and the extensions blocked dozens of Workday admin pages (44–56) to hinder incident response.

- **Credential-stealing family (Feb 2026):** per Malwarebytes, 30 Chrome extensions were found stealing credentials from more than 260,000 users by overlaying a remotely hosted full-screen iframe, using "extension spraying" to evade takedowns. Extensions evade EDR because they operate inside the browser after authentication, with no binary dropped on disk.
3. **Can a Python/C++ keylogger run from USB or the Startup folder WITHOUT admin rights, and does Smart App Control/Defender reliably catch homemade ones? Yes to the first —** `pynput`-based keyloggers run as a standard user, can be launched as `.pyw` to hide the console, and persist via the user-level `HKCU\...\CurrentVersion\Run` key or the Startup folder (all user-writable, no admin needed). On the second, there is a **real detection gap**: Microsoft confirms Smart App Control blocks an app only "if the app is unsigned, or the signature is invalid" *and* the cloud service can't confidently judge it — but SAC is off/evaluation-mode on most existing or upgraded installs and operates on Mark-of-the-Web files; Elastic Security Labs documented bypasses (including LNK-handling bugs). Signature-based Defender does not reliably catch a freshly written, never-before-seen homemade keylogger. **This is precisely why execution prevention (WDAC/AppLocker + reboot-restore + no-admin) is more important than relying on detection.**
 4. **Most effective way to block USB-based threats on lab machines?** Layered: (a) Device Installation Restrictions default-deny + hardware-ID allowlist for sanctioned devices; (b) "Removable Disks: Deny execute access" to stop payload execution while allowing data transfer; (c) WDAC/AppLocker so even a copied executable can't run; (d) Defender for Endpoint/Intune device control for central management and audit logging. The crude USBSTOR `Start=4` registry kill-switch is a belt-and-suspenders measure, not a primary control (it can be reverted by management agents/updates and blocks legitimate workflows).
 5. **How to disable Google sync for a university domain account:** In the Google Admin console (admin.google.com): **Apps → Google Workspace → Google Chrome Sync → Edit Service → OFF for everyone** (or per OU with Override). Reinforce on managed browsers with the `SyncDisabled`, `BrowserSignin`, and `RestrictSigninToPattern` policies. Google states the Admin console toggle is the authoritative method to fully turn off sync services.
 6. **Real-world effectiveness:** Removing admin rights alone is reported to mitigate up to 75% of Microsoft critical vulnerabilities (2025 BeyondTrust report). Combined with reboot-to-restore, harvested credentials and any installed logger are erased on restart; combined with browser sync/password-manager lockdown, the highest-yield credential target (saved passwords + DPAPI-decryptable "Login Data") is removed entirely. There is no single published controlled study quantifying the exact *combined* reduction, so this should be framed as defense-in-depth where each layer closes a documented attack path.

The data-remanence / offline-extraction risk this defends against

On a shared Windows machine, Chrome/Edge store saved logins in an SQLite "Login Data" file, encrypted with an AES key wrapped by Windows DPAPI under the user's context (the key is in the JSON "Local State" file, prefixed "DPAPI"). Anyone who can run code as that *same user* on that *same machine* (e.g., the next student, or an attacker who left tooling behind) can decrypt them offline with tools such as **SharpChrome, HackBrowserData, LaZagne, or mimikatz**

`dpapi::chrome`. This is exactly why lab machines must (a) not save passwords, (b) not persist profiles across sessions, and (c) wipe state on reboot. Note: Chrome 127+ **App-Bound Encryption** raises the bar for pure "dead-box" offline extraction (Elcomsoft notes it "broke the dead box workflow"), but it does **not** protect against code running inside the user/browser context — malicious extensions or injected code inherit the browser's trusted identity and bypass it.

ElcomSoft

Details

Why shared lab PCs are uniquely dangerous

A shared lab PC violates the core assumption browsers and OSes make — that one machine $\approx$ one trusting user. Students sign into email, university portals, social media, and cloud drives; browsers offer to save passwords and sync; the next user inherits whatever persisted. Three attack surfaces matter: (1) **credential remanence** — saved passwords, cookies, session tokens, cached form data; (2) **sync leakage** — a signed-in Chrome/Edge profile silently mirrors passwords/bookmarks/history to a personal cloud account, and conversely pulls a victim's data *down* onto the shared box; (3) **malware persistence** — a keylogger or malicious extension left by one user harvests the next users' keystrokes and credentials.

Recommended NSU lab baseline (concrete)

1. **Accounts:** Students log in as standard users only; no local admin. (Mitigates up to 75% of Microsoft critical vulns and prevents most software installation.)
2. **State wipe:** Deploy Deep Freeze or UWF so every reboot restores a clean image. Schedule reboots between class sessions.
3. **Browser:** Enforce via Workspace/GPO — disable sync, disable the built-in password manager, force sign-in restricted to the university domain, block personal-account sign-in, allowlist only approved extensions, and set a short Browsing Data Lifetime.
4. **USB:** Default-deny installation + deny-execute on removable disks; allowlist sanctioned hardware IDs; manage centrally with Intune/Defender Device Control where possible.
5. **App control:** WDAC (or AppLocker) allowlist with hash/publisher rules so non-admins can only run approved, signed software — the real defense against homemade keyloggers that Defender misses.
6. **Monitoring:** Sysmon $\rightarrow$ Wazuh to alert on new Run-key/Startup-folder/scheduled-task persistence and credential-store access patterns.

7. **MFA everywhere** so that even a stolen password is insufficient — the most important compensating control, since no endpoint defense is perfect.

The gendered dimension (why this matters at NSU specifically)

Credential theft from shared/public machines is a direct pipeline to image-based abuse and account-takeover that disproportionately harms women. Per the Dhaka Tribune citing Police Cyber Support for Women (PCSW) data, "60,808 women approached authorities for cybercrime cases by September 2024... doxxing accounted for 41 per cent, followed by account hacking at 18 per cent, blackmail at 17 per cent, impersonation at 9 per cent and cyberbullying at 8 per cent." (The Daily Star reports the same 60,808 figure cumulatively from the unit's inception in Nov 2020 to May 2024.) ActionAid Bangladesh's "Online Violence Against Women 2022" study found "a total of 63.51% of women respondents reported facing online violence, which was 50.19% last year" (survey of 359 women aged 15–35 across six districts; the most common harm was "hateful and offensive sexual comments (80.35%)"). Earlier research (Zaman, Gansheimer, Rolim & Mridha, 2017) found 73% of women internet users reported cybercrime; a widely reported case involved a BUET CSE student and accomplices spreading offensive photographs. The academic framing connecting shared-device security failures to gendered harm runs through the Bangladesh/South Asia HCI literature (Ahmed et al. CHI 2017/2019; Sambasivan et al. SOUPS 2018), which shows women's devices and accounts are routinely monitored and controlled by others — making a clean, non-persistent shared lab machine a genuine *safety* control, not just a hygiene measure. [usenix](#)

Recommendations

Stage 1 (immediate, low-cost — GPO/Workspace config, zero new licensing): Enforce standard-user accounts; disable Chrome/Edge sync and the built-in password manager via policy; restrict browser sign-in to the NSU domain and block personal-account sign-in; enable "Removable Disks: Deny execute access."

Stage 2 (core hardening): Deploy reboot-to-restore (UWF if Enterprise/Education licensing exists, else Deep Freeze) with scheduled reboots; roll out WDAC/AppLocker allowlisting in audit mode first, then enforce with hash/publisher rules. *Benchmark:* a homemade [pynput](#) keylogger dropped in the Startup folder should fail to execute and should not survive a reboot.

Stage 3 (detection & governance): Stand up Sysmon→Wazuh monitoring; require MFA on all student/staff accounts; publish a lab-use policy and a fast, confidential reporting path for image-based abuse/account compromise (modeled on PCSW). *Benchmark to revisit controls:* any confirmed credential-theft incident traced to a lab machine, or any keylogger/extension found surviving a session.

What would change the recommendation: If labs run Windows Pro (no UWF), prioritize Deep Freeze. If central management (Intune/Defender) is unavailable, lean harder on GPO + reboot-

restore. If MFA coverage is already universal, the marginal value of perfect endpoint lockdown drops, and effort can shift to monitoring and user education.

Caveats

- The "up to 75% of Microsoft critical vulnerabilities mitigated by removing admin rights" figure is the 2025 BeyondTrust framing (12th edition, 2024 CVEs); prior single-year figures were *higher* (77% for 2019, 81% for 2018), and recent editions increasingly emphasize identity-based/Elevation-of-Privilege attacks. Treat it as directional, not exact.
- No single peer-reviewed study quantifies the exact *combined* reduction in credential exposure from "standard-user + reboot-restore + browser lockdown"; the case rests on each layer independently closing a documented attack path (defense-in-depth), not on one controlled experiment.
- Several institutional how-to specifics (GPO paths, registry keys) come from reputable practitioner sources and vendor docs rather than peer review; the authoritative anchors are **Microsoft Learn** (UWF, WDAC, device control) and **Google Workspace admin Help**.
- Bangladesh statistics are reported via news outlets (Dhaka Tribune, The Daily Star) citing PCSW/ActionAid, and via GSMA — cite the originating body where possible; the PCSW total has been variously reported as "by September 2024" and "Nov 2020–May 2024," so present it with that ambiguity noted.
- Smart App Control behavior depends on mode (it is off/evaluation on many existing installs) and Windows version; verify on the actual lab image rather than assuming protection.
- The Feb 2026 "30 extensions / 260,000 users" campaign is sourced to a single vendor (Malwarebytes) and could not be independently corroborated during research; the Jan 2026 Socket-disclosed Workday/NetSuite/SAP cluster is the more firmly multi-sourced enterprise-extension example.